Journal of Cybersecurity, 2026, **12**(1), 1–19
https://doi.org/10.1093/cybsec/tyag010
Research Paper

End-to-end encryption, chat control, and the future of the right to encryption in digital services

Marcin Rojszczak *

Faculty of Law and Administration, University of Gdańsk, Gdańsk, Poland
*Corresponding author: Faculty of Law and Administration, University of Gdańsk, ul. prof. Marii Janion 5, 80-309 Gdańsk, Poland. E-mail: marcin.rojszczak@ug.edu.pl

Abstract

One of the pressing issues in the regulation of digital communications services is how to ensure effective cryptographic protection of user communications. This issue is analysed in relation to the so-called "right to encryption" and the risks associated with using encrypted messengers to disseminate illegal content, including CSAM and extremist content. The response to this threat is various countries' adoption of a new category of regulations, which deliberately weaken certain traffic encryption techniques in order to enable service providers or public authorities to monitor the content of messages. This problem relates to end-to-end encryption (E2EE) in particular, which is widely used in leading communication services. The aim of this article is to discuss a *ratio legis* and present possible regulatory strategies for weakening E2EE that could be considered by EU legislature. Although the draft EU CSAM Regulation will serve as the backdrop for these considerations, the issue of regulating E2EE will be examined from multiple angles—starting with an explanation of its technical aspects, moving on to the reasons for the proposed regulation of its use, and ending with an analysis of the regulations that have been proposed or implemented in selected countries (Russia, the USA, and the UK). This paper outlines a proposal for the implementation of a horizontal EU act on the security of encrypted communications, applicable not only to one specific sector, but also affecting the entire EU digital market. It further argues that EU regulatory policy should be based on a hybrid regulatory approach, integrating normative obligations with technical design choices to adequately protect user transmissions without hindering the fight against serious crime.

Keywords end-to-end encryption, right to encryption, encryption regulation, electronic communications, key escrow, chat control

Introduction

When the European Commission presented the draft EU CSAM Regulation in 2022 [1], one element that caught the attention of experts was the inclusion of providers of certain types of electronic communications services within the scope of new content control and moderation measures. The draft imposed the obligation to prevent the dissemination of CSAM content on not only providers of information society services (hosting services in particular), but also providers of so-called non-number-based electronic communications services.[1] In EU law, the latter group includes online messaging services.[2] The regulatory concept presented in the EU CSAM Regulation seemed convincing—if the legislators' intention is to decisively fight the abuse of children, there is no justification for why measures in this area should only apply to certain types of digital services, such as hosting services.

The evolution of the digital services market has meant that communications services—originally designed as tools for interpersonal communication—are increasingly being used in a way that resembles social media. Today's instant messaging services offer content distribution functionality that goes far beyond the needs of exchanging messages within a family or a small group of friends. It is difficult to consider that the ability to create groups of more than 1000 people (as in WhatsApp) [4] or channels with no restrictions on the number of recipients (as in Telegram) [5] fulfils an individual's need for interpersonal communication.[3]

Changes in the services market, including the ways in which users themselves use individual services, have gradually blurred the distinction between traditional hosting services and communications services. This, in turn, led to the observation that since a communications service can be—and increasingly is—used in a similar way to a social networking site or hosting service, it should also be regulated in a similar way.

However, it is not without reason that EU law distinguishes between the regulatory instruments—including legal safeguards—applied to different types of digital services. While typical hosting services are used to disseminate information, communications services are used to transmit it to specific recipients. Thus, the latter have traditionally been associated with the right to privacy

[1] Art. 1(1)(b) of Draft EU CSAM Regulation [1].
[2] The so-called "number-independent interpersonal communications service"—see Art. (2)(7) of EECC Dir. [2]. For more on the classification of OTT-0/1 services in EU law, see [3].
[3] In Telegram, apart from channels with no member limit, it is also possible to create groups in which up to 200 000 people can exchange information.

Received: 3 October 2025. **Revised:** 12 February 2026. **Accepted:** 23 March 2026
© The Author(s) 2026. Published by Oxford University Press. This is an Open Access article distributed under the terms of the Creative Commons Attribution License (https://creativecommons.org/licenses/by/4.0/), which permits unrestricted reuse, distribution, and reproduction in any medium, provided the original work is properly cited.

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

and, in the constitutions of many countries, *explicite* with guarantees regarding the protection of communications. Therefore, a telecommunications service provider could not legally examine what messages communicating users were transmitting or determine whether they were definitely not breaking the law or discussing breaking the law in that correspondence.

Of course, telecommunications secrecy has never been an absolute right. The debate on the limits and necessity of using legal wiretapping techniques—especially in criminal proceedings—is a hot topic in most legal models. However, applying a specific exception, such as the lawful interception of communications, is different from establishing a permanent control model that requires service providers to verify that their services are not being used to break the law.

For years, in democratic countries, the issue of so-called preventive content analysis has been addressed almost exclusively[4] in regulations aimed at hosting service providers. Controversy in this area has led to numerous disputes in which both domestic and European courts have examined the limits of content control in relation to users' online activities [6]. The issue of removing (blocking) illegal content has been addressed in relation to countering various forms of hate speech [7,8],[5] preventing copyright infringements [11,12] and combating extremist content.[6] In each case, however, the main focus was on the impact these techniques have on the right to freedom of expression, setting aside any questions about their impact on the right to privacy.[7] However, the blurring of the line between hosting and communications services has led to more and more proposals that similar measures, which have been applied to the former for years, should also be applied to the latter.

Leaving aside the constitutional controversy, namely whether and how respect for the secrecy of correspondence can be reconciled with the preventive analysis of its content, this attempt to apply techniques that are commonly used in hosting services to the world of communications services encounters yet another obstacle, this time of a technical nature. In order for a service provider to assess whether a message (content) distributed through its service violates the law, it must first be able to read it. However, unlike hosting services, communications services in most cases use various encryption techniques to protect content from unauthorised access. A special form of this protection is end-to-end encryption (E2EE), which, if implemented correctly, effectively prevents any third party from inspecting the content.

Thus, in many countries, the debate on the need for greater protection of users (especially children) against online abuse has led to a dispute over the necessity and limits of E2EE in instant messaging applications. This issue has for years been presented as an irresolvable conflict between the right to privacy and public safety [14,15]. In this context, legislators were faced with the choice of whether to continue to uncritically accept the use of E2EE—thereby reducing the effectiveness of measures to combat the dissemination of illegal content—or to establish legal instruments limiting the use of this technology, thereby accepting the introduction of a systemic threat to the privacy of communications [16].

This article examines whether the regulatory problem of E2EE can be addressed without resorting to either its unrestricted use or a general prohibition. It argues that this can be achieved by combining technical capabilities with modern legislation through the adoption of a new EU horizontal act.[8] Such regulation would supplement the current regulatory framework for the telecommunications sector by setting minimum standards for the cryptographic protection of interpersonal communications and procedures and conditions for the introduction of lawful restrictions on this technology. The proposed regulation would affect the entire communications services market, raising user protection standards, limiting the freedom of service providers to make arbitrary decisions, and establishing transparent and reliable rules for accessing encrypted content.

To develop this argument, the article first explains the technical foundations of E2EE and the ways in which it operates in practice. It then examines how E2EE can be weakened or bypassed in order to enable content control, and it analyses selected regulatory strategies adopted in nondemocratic states (Russia) and in close trading partners of the EU (the USA and the UK in particular). This comparative analysis provides a basis for assessing the regulatory options available to the EU and for identifying how European regulatory policy can be shaped so as to prevent digital services from becoming spaces for the unpunished dissemination of illegal content, while avoiding permanent restrictions on high standards for protecting communication secrecy.

E2EE: a technical primer

Transmission encryption protects the confidentiality of communication and ensures its integrity. Often, the algorithms used to protect confidentiality also allow any interference with the content of the message to be detected. Moreover, because online communications have always been vulnerable to unauthorized interception and manipulation, most of the popular services in fact cryptographically protect transmissions. In many cases, users are not even aware that their communications are encrypted or how this protection is provided.[9]

In the case of the simplest communications services—i.e. those used to exchange information between two users—E2EE involves the use of a preagreed password (known as a session key).[10] This key is either transmitted using asymmetric cryptography or agreed upon using one of several common methods for this purpose (such as Diffie–Hellman protocol) [19]. In each case, however, only the communicating parties—the sender and the recipient of the message—have the key, without which the plaintext message

[4] One exception is indiscriminate surveillance systems, which have also been based on preventive information analysis mechanisms for years. However, such solutions are used in the area of state security and, as a rule, should not be used to achieve other public objectives.

[5] For discussion, see [9,10].

[6] This issue is discussed in particular in relation to the Terrorist Content Regulation (2021/784)—see e.g. [13].

[7] This was due to the fact that hosting services—which used content moderation measures—are generally used to disseminate (publish) information that the user himself wants to disclose. Blocking content that the user intended to disseminate did not, therefore, constitute interference with his right to privacy *per se*, as the user's activity was not of a private nature.

[8] By a "horizontal act," this article refers to an EU-wide framework regulation applicable across sectors and complementing sector-specific instruments, such as the draft CSAM Regulation, discussed later in this text.

[9] Against this background, it is worth recalling the controversy which took place during the COVID-19 pandemic surrounding the scope of encryption techniques used in instant messaging applications. As it turned out, a significant proportion of users were unaware of whether their communications were encrypted and how, and were unable to use group work tools securely. For an example regarding the popular Zoom tool, see [17].

[10] For an introduction to the principles of using cryptography in E2EE, see [18].

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

cannot be recovered from the ciphertext. And since the sender and recipient of the message have the same, securely agreed encryption key, they can communicate with each other without the risk of unauthorised access to the message. As long as they use a reliable[11] encryption algorithm, their correspondence—even if intercepted by a third party (e.g. a service provider)—cannot be read (or its content analysed).

In the real world of instant messaging, however, this model of secure communication is overly simplified. First, a user may correspond with multiple recipients—and therefore must have as many session keys as there are people with whom they communicate. These keys are generated automatically by the communication application (e.g. WhatsApp) and, as a rule, are not stored on any other device. WhatsApp users do not create cryptographic keys themselves; the entire process of generating and managing them is carried out by the application. Moreover, these keys are periodically updated (changed), which also happens according to algorithms over which the user has little (or no) control. However, the security of their communication still depends on third parties not having access to the keys.[12]

Secondly, instant messaging applications not only allow for encrypted communication with different people, but also for groups. In this case, the message is encrypted using multiple keys during its transmission, which allows it to be read later by any recipient with whom a cryptographic key has been agreed. Usually, the message is encrypted with a single session key, which is then encrypted separately for each recipient—either with a key previously agreed with that recipient or with their public key. In this way, E2EE can also be used by a group of people at the same time, potentially covering not only text transmissions, but also voice or video chats. And—as with individual communication—if the service provider has correctly implemented recognized encryption algorithms, this communication is secure and cannot be easily analysed by a third party.

In reality, however, the implementation of full E2EE faces obstacles, both regulatory (more on that later) and related to the architecture of the service or the provider's business model. In other words, what is referred to as "encrypted communication" does not always use E2EE, even if the information being transmitted is actually protected by cryptography. To understand this limitation, it is enough to compare how the service is provided in two leading instant messengers: WhatsApp and Telegram. Messages transmitted on WhatsApp, for both individuals and groups, are always protected using E2EE [21]. Users cannot "turn off" this method of transmission protection or (unknowingly) choose a type of communication that offers lower protection. Moreover, the service provider (Meta) has made available a detailed description of the protocols it uses, which in the case of WhatsApp is the recognized and reliable Signal protocol (the same one used in the application Signal) [22].

Telegram, on the other hand, has created its own protocol, based in part on proprietary solutions [20]. It is noteworthy that the encryption used in Telegram is only implemented in some cases in an end-to-end model. As a rule, Telegram relies on so-called transport encryption (client-server-client)[13]—i.e. encryption between the sender and the central node (the service provider's servers) and then between the service provider's servers and the recipient.[14] Although transport encryption can be as effective as E2EE in many cases, it does not protect communications (that is content data) from being viewed or interfered with by the service provider or, potentially, by entities with which the service provider is legally obliged to cooperate.

Telegram uses transport encryption for all group chats and, by default, for interpersonal communication [23]. The application offers the option to use a private mode (called Secret Chats), which provides E2EE between users, but this is an additional option and not the standard for communication [24].

However, even when E2EE is used, the actual level of transmission protection depends not only on the cryptographic protocols being used (and how they are implemented), but also on what exactly is being encrypted. Software developers have considerable freedom in setting their policies. There is nothing to prevent E2EE from covering only certain categories of information (e.g. not covering metadata or certain types of attachments) or from being used in parallel with transport encryption, meaning that some information about how the service is used will still be made available to the service provider.

Why should E2EE be regulated or limited at all?

The technical maturity of E2EE systems means that, if this technology is implemented correctly, neither the service provider nor any other entity can view the information being transmitted. As a rule, this also means that the transmitted information is not susceptible to unauthorized manipulation (alteration). It is worth remembering that it is not necessary to have access to the plaintext message in order to modify it (e.g. by deleting or adding new content, such as email attachments). In practice, however, it is not the integrity of messages protected by E2EE that poses a regulatory problem, but their confidentiality. The use of this technology prevents both the service provider and other entities—including public authorities—from viewing the content being transmitted, even if they have a legitimate legal interest in accessing it.

The main argument in favor of introducing restrictions is that encrypted services may be used for criminal activities, particularly those related to the distribution of illegal content.[15] Especially troubling are recurring reports that communications services are increasingly being used to disseminate highly harmful content, such as CSAM or content promoting or glorifying acts of terrorism [26]. It appears that the perpetrators of such violations can more easily transmit incriminating materials using modern communi-

[11] Therefore, one that is based on recognized international standards that have undergone detailed technical verification. An example of a product that uses its own cryptographic protocol is Telegram. The MTProto algorithm used in the tool is open-source, and the first study to formally verify its security has recently been published in [20].

[12] In this case, the "third party" is any person who is not a participant in the communication—and therefore can refer to the service provider.

[13] This technique is also sometimes referred to as server-side encryption (SSE), Because this term is used to describe both the encryption of stored data and its use in the encryption of transmissions, it can be misleading.

[14] This is the main difference between E2EE and transport encryption. With E2EE, encryption is applied between the sender and recipient of the information, which means that the content of the message remains encrypted throughout the entire transmission.

[15] In this regard, it should of course be remembered that E2EE restrictions can also be a useful tool for achieving national security objectives. However, as the purpose of this article is to critically discuss the regulatory proposals presented in the EU and the area of national security is generally outside of the scope of EU law, the issue of the impact of E2EE restrictions on national security will not be analysed in detail. I discuss the relationship between EU (digital) law and national security in more detail in [25].

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

cations services, e.g. by creating large distribution groups resembling social media channels [27]. At the same time, this type of activity is not subject to the restrictions applied in hosting services to block the dissemination of illegal content (including "upload filters"[16]).

Although the purported link between encrypted communication and the growth of serious crime is often repeated, it is impossible not to notice that there is a lack of grounded research confirming such a link—for crimes other than those related to the distribution of CSAM. On the contrary, there are analyses indicating that no such link exists [31]. In this case, the question is therefore not whether criminals use digital services, but whether the scale and intensity of criminal activity increase due to access to technologies, such as E2EE.

Proponents of restricting (weakening) E2EE also point out that the widespread use of encryption in communication not only prevents service operators from filtering content, but also prevents law enforcement agencies from accessing messages [32]. This limits the effectiveness of measures used to combat crime, contributing to the risk of creating enclaves of impunity in certain digital services [33].

Although both positions support the restriction of E2EE, they differ in terms of the intended purpose of introducing such a limitation. In the case of combating the dissemination of illegal content, the aim of regulatory policy should be to create a situation in which the service provider is able to inspect traffic *en masse*.[17] Therefore, any solutions would have to ensure that the provider could decrypt all traffic carried on its service in order to eliminate those transmissions that contain clearly illegal material.[18]

On the other hand, the service provider does not, in principle, require access to the communication itself in order to perform lawful interception. This access is to be granted to an authorized body, which can be achieved without also extending access to the service provider. There are no technical obstacles to allowing (full or partial) decryption of traffic only to a public authority, but not to a service provider.

Going even further, the possibility of public authorities decrypting transmissions may be introduced in the form of a permanent measure allowing for the decryption of any transmission between any users, or as a temporary mechanism. In the latter case, one would expect the introduction of a technical and organizational separation of powers regarding the authorization of lawful interception and the actual interception and decryption of communications using a temporary key that is active for a strictly specified period [31].

In the ongoing discussion, unfortunately, such nuances are usually overlooked by proponents of limiting the use of encryption, which inevitably oversimplifies and muddies the debate. This has resulted in the slogan "weakening E2EE" being used to describe a number of different proposals, some of which can only be implemented using technical means, others which also require procedural and legal measures and still others, which are simply technically unfeasible and arise from a lack of deeper understanding of how the technology to be regulated works.[19]

At the same time, a significant part of the public debate on E2EE frames encryption as a direct synonym of privacy. As a result, E2EE is described as a guarantor of private communication [36], with the "right to encryption" being a component of the right to privacy [37,38]. In this context, any regulation of this technology should also be assessed in light of the potential infringement of fundamental rights [39]. Unfortunately, such arguments often lead to a simplification of the discussion on the technical aspects of E2EE, equating the establishment of restrictions on the use of this technology with a general ban on the use of (any) transmission encryption. This type of argument is conceptually inconsistent for several reasons.

Starting with the fundamental issues, the discussion on E2EE regulation should be conducted within a regulatory environment within which such regulations may be applied in future. Referring this issue exclusively to democratic countries, cryptographic protection of communications is, first and foremost, a means of protecting the confidentiality of communications; as such, it is related to the individual's right to privacy and, in the case of the European legal model, to the right to personal data protection.[20] Although both the right to privacy and the right to data protection are considered fundamental rights, they are not absolute. This means that in European legal models, it is possible to establish lawful restrictions on the exercise of these rights if such restrictions are necessary and proportionate and they respect the essence of these rights [41]. Apart from constitutional differences regarding the limitation and derogation of fundamental rights,[21] there is no doubt that the very recognition of the possibility of introducing them leads to the conclusion that such restrictions—in particularly justified cases—may also apply to measures used to protect these fundamental rights, such as E2EE. To put it simply, if E2EE is recognized as a means of protecting user privacy, the very fact that this right is not absolute means that the legal model must also provide for rules on lawful access to encrypted communications.

Secondly, when criticizing proposals for the regulation of E2EE, watchdog organizations often call for no restrictions (of any kind) to be imposed on service providers in the use of this technology. However, they do not propose introducing an obligation for service providers to make E2EE features freely available to users of publicly available communications services. And this is what should be expected in the first place. If we accept that the "right to encryption" exists (e.g. as a component of the right to privacy), then it is a subjective right of service users, not operators. There is no reason why technology companies should decide which encryption mechanism, if any, to introduce to protect users' rights,

[16] In EU law, the term "upload filter" is usually associated with provisions on hosting services, in recent years in particular with the implementation of Article 17 of Directive (EU) 2019/790 [28]. See also [29,30].

[17] For this reason alone, comparisons between this type of instrument and bulk surveillance systems are clearly justified. Decrypting all traffic *en masse* solely because one of the users may be breaking the law is nothing more than eliminating the right to privacy due to a hypothetical (unspecified) threat to public safety.

[18] Reference is also made to provisions requiring hosting service providers to counteract the dissemination of manifestly unlawful content. For more on clearly unlawful content in digital services, see [34].

[19] The best example is the public statements made by UK Home Secretary Amber Rudd [35], who, while working on far-reaching proposals to ban the use of E2EE, admitted that she did not understand how the technology works.

[20] It should be noted that the right to data protection is explicitly mentioned in both the Charter of Fundamental Rights and the constitutions of many Member States. In this sense, it is an independent right, serving to ensure the actual informational autonomy of individuals and control over the processing of their personal data. As a result, under European law, a violation of data protection rights may occur even if there has been no violation of the right to privacy. See also [40].

[21] It should be noted that in some constitutional systems, the right to privacy is absolute, to a certain extent; this is the case in the German model, for example, where the so-called core area of private life is not subject to any derogation or restriction, which excludes any interference in this sphere by the state, regardless of the reasons for such interference.

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

Table 1. Basic models for weakening E2EE communication.

Model	Type of interference	Intrusiveness	Complexity of implementation	Risk of abuse
Traceability of E2EE traffic	Data in transit	Low to moderate	Low	Low
Replacing E2EE with transport encryption	Data in transit	Moderate to high	Low to moderate	Low to moderate
Key escrow (using third-party keys)	Data in transit	High	Moderate to High	High
Access to cloud backups	Data stored (server-side)	Moderate	Low	Moderate
Client-side scanning	Data stored (client-side)	High to extremely high	High	High to extremely high

Explanatory note:.
- As individual regulatory models often describe a set of instruments, the assessment presented here is purely illustrative and aims to facilitate an understanding of the relationships between the models.
- Intrusiveness is assessed in terms of a qualitative evaluation (access to some or all communications), quantitative evaluation (individual or large-scale access), and potential access to data unrelated to electronic communications.
- The complexity of implementation describes the technical difficulty of implementing individual regulatory models as mandatory instruments in the European digital market. It is therefore an evaluation of the technical complexity involved in implementing each proposal.

as this type of freedom of choice is *inherently* at odds with the concept of a "right to encryption." In other words, the existence of the right to encryption should be accompanied not only by negative obligations, but also by positive ones.

Likewise, claims that E2EE *per se* constitutes a barrier to the use of intrusive surveillance measures are not convincing [42]. It is easy to imagine a service model in which, despite the use of E2EE, users' activities can be subject to far-reaching surveillance by public authorities.[22] E2EE technology protects data in transit, but does not in itself secure data stored on either the subscriber's device or the service provider's servers. Also, the freedom of service providers to create the rules of traffic encryption—often combined with a lack of transparency about the algorithms they use—means that the same service can use elements of E2EE while also transferring protected information to the provider's servers (e.g. with transport encryption). The result is an illusion of protection, in which the provider can confidently advertise its product as using the E2EE label, while in reality it is engaged in far-reaching activities that allow user profiling. E2EE technology is a technological solution; it was not created as a synonym for "privacy protection" and should not be interpreted as such.

In the case of the EU, there is no doubt that the discussion surrounding the weakening of E2EE is dominated by the "privacy versus security" debate. While this framing may seem convenient for both sides, it often leads to fruitless discussions. Setting aside the validity of pitting the needs and values of individuals (personal security) against the goals of the state (general security objectives), this approach to the problem makes it difficult to find a middle ground: one can either preserve privacy or ensure security. In my opinion, this is not the case in reality. A reasonable legislature, when creating regulations and taking into account the possibilities offered by the technology being regulated, can adopt provisions that reconcile the needs and goals postulated by both supporters and opponents of the widespread use of E2EE.

Inspiration in this regard can be found in the work of Susan Landau, who almost a decade ago proposed that the discussion on weakening technology should not be framed as "privacy v security" but as "security v security" [43]. She argued that the role of the state is to strengthen the cybersecurity of society, not to weaken it. Deliberately weakening security (e.g. by introducing hidden vulnerabilities or backdoors) may achieve short-term security goals (e.g. related to data access) but undermines long-term goals related to building the cyber resilience of citizens and entire societies.

At the same time, however, Landau's argument was built in relation to applications strictly related to electronic surveillance. Consequently, it does not always address today's challenges related to E2EE regulation in digital services.[23] Despite this limitation, I believe that it is possible to reconcile the needs of different stakeholders and propose an E2EE regulatory model that, when implemented technically, will transcend the dichotomy of "privacy v security". In further analysis, I discuss arguments supporting the possibility of creating such a regulatory framework, with the aim of presenting a specific regulatory model in the final section of the paper.

Different shades of weakening E2EE systems

Without prejudging whether the introduction of regulations aimed at limiting (or *weakening*) the use of E2EE in consumer products is necessary at all—particularly whether such a measure can be considered necessary (least intrusive) to achieve a legally justified objective—it is worth briefly discussing possible models for achieving this task (see Table 1).

The first three sections discuss E2EE restriction models that impact the security of transmitted information. These models directly affect the selected communication protocols. They are presented from the least intrusive (traceability) to the most radical (key escrow). Additionally, in subsequent subsections, alternative

[22] It suffices to recall that the most extensive mass data collection programmes have been successfully implemented for years in democratic countries, such as the UK and the USA, where E2EE technology is not prohibited.

[23] An example of this is the ongoing debate in some European countries about restricting children's and young adults' access to harmful content. This refers particularly to material relating to eating disorders or promoting anxiety or depression. Content of this type is widely distributed online, including on instant messaging services. However, implementing an obligation for service providers to block such material, as proposed in the UK, among other places, would require them to be able to inspect the content of encrypted communications (E2EE). In this case, the aim is not to glean information from the communication, but to protect particularly vulnerable users from content that is not intended for them.

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

models for weakening E2EE are presented, which in fact do not strictly concern the encryption protocols of transmitted data. Nevertheless, these models have a similar effect and can be used as an alternative to classic E2EE weakening. This is particularly relevant in the context of accessing data stored in the cloud and data filtering on the subscriber's device (client-side scanning).

It is important to remember that the models for interfering with E2EE security presented here are only examples. In reality, as will be demonstrated in the next section, legislatures often combine the solutions from different models to create hybrid instruments. However, examining these models in closer detail is sufficient to understand the possible policy options and associated technical possibilities.

Traceability

The first strategy is to ensure that the service provider is able to determine (and disclose to the competent authorities) information about how users use the service, by providing traffic data (i.e. billing information) showing how often and with whom a user communicated. This does not equate to intercepting encrypted communications, but rather determining that user A communicated with user B at a specific time, or more generally, identifying and creating a report of all the people with whom user A communicated during a given period.

In the case of direct data transfer from sender to recipient, the service provider will not even be aware that communication is taking place. Nor is it possible to collect any (meta)data about it. Although this service delivery model can be considered to protect users' privacy in the most comprehensive way, it also does have its limitations. First, direct communication between the users means that the communication protocol must disclose the actual IP address of the message's recipient to the other party. Even disregarding the actual effects of such a solution on user privacy (in other words, whether the user prefers to disclose information about themselves to the service provider or to the people with whom they are communicating), in some cases the implementation of such a solution is simply technically impossible (or severely limited). This particularly applies to communication within group chats, where messages are distributed (sent) to multiple recipients. For practical reasons (service stability and performance), sending, for example, a video stream individually by sender to all recipients in real time could lead to a drastic decline in service quality.

Therefore, even when E2EE is being used, in practice, data transmission is forwarded via the service provider's servers (this is the case, for example, with WhatsApp). In this case, it is worth remembering that in order to be able to properly handle communication within a group, the service provider must know who belongs to that group. As a result, although they do not know the content of the information being transmitted (because it is encrypted), they know when and to whom the messages are sent. It follows that traceability for some E2EE traffic can be ensured without any restriction or modification of the rules already in place.[24] Therefore, traceability understood in this way does not lead to *a weakening* of security, since service providers already have access to all the data that needs to be collected.[25]

In reality, however, in some proposals, the term E2EE traceability is understood to mean the addition of special tags to help establish the identity of the communicating parties [46,47]. In such a model, in addition to the encrypted message itself, data packets would be additionally tagged in a way that would allow public authorities to determine patterns of communication. Although this extended version of traceability does not weaken E2EE *per se* (interference with cryptographic algorithms), it does in fact lead to an infringement of user privacy.[26]

In the case of traceability, the regulatory challenge is not so much about implementing the appropriate technical measure, but rather about demonstrating the proportionality and necessity of service providers collecting metadata. This problem is therefore analogous to that discussed for over a decade in relation to the so-called general data retention obligation [49–51]. In this context, traceability in relation to popular instant messaging services—leading to service providers collecting traffic data—is not a technical issue involving the weakening of E2EE, but primarily a regulatory and legal issue. In this regard, it is also worth noting that there are proposals to implement E2EE protocols that ensure traceability strictly in relation to illegal content [52].

In order to not overgeneralize, it should be noted that there are also instant messengers based entirely on peer-to-peer protocols. Here, messages between users are not sent via central nodes (service providers), but directly to the message recipient's device. In this case, ensuring traceability would actually require a redesign of the service. However, this is a marginal problem, as most instant messengers of this type are also distributed services—operating without a designated central node. In such cases, there is no classically defined "service provider," but rather an application provider or an entity responsible for developing the communication protocol (e.g. Briar or Tox).

Transport encryption and quasi-E2EE

The second regulatory strategy discussed in the context of weakening E2EE ensures that encrypted transmissions can be inspected by a third party (other than the recipient)—the service provider or an authorized public authority (law enforcement or special forces) in particular.[27] The simplest way to implement this proposal is to replace E2EE with transport encryption mechanisms (client–server–client encryption). From a functional point of view, this does not even require a change in the cryptographic algorithms being used; traffic would simply be encrypted in the sender—service provider relationship and then in the service provider—recipient relationship. As indicated above, this is the default form of encryption offered in some instant messengers, including Telegram.

[24] This information is indirectly confirmed by a summary released by the FBI describing the Bureau's capabilities for obtaining data from various encrypted services—see [44].

[25] For the purposes of this text, the issue has been simplified somewhat. For example, in Signal, the sender's identity is unknown, although the communication is transmitted via the provider's servers (a so-called "sealed sender") [45]. In fact, depending on the cryptographic model in use, it is possible to hide some of the transmitted metadata from the service provider.

[26] But it is also true that even without transmission tagging, a simple traceability model (based on metadata available to the service provider) can be used to deanonymize conversation groups through traffic analysis [48].

[27] This strategy assumes access to all traffic (in most cases), but hybrid models are also being explored—in which transport encryption is used only for part of the communication (more on this below).

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

In reality, however, this solution does not so much weaken E2EE as replace it with another form of cryptographic communication protection. The result is full visibility of user transmissions for the service provider, enabling them to implement various techniques for analysing transmissions. In this case, there are no longer technical limitations preventing the introduction of extensive obligations on providers to identify or prevent the dissemination of certain categories of content. Of course, if the service provider has access to the content of communications, so does any entity that can legally compel the provider to disclose that information. Therefore, giving the service provider the ability to control user communications leads to the most far-reaching erosion of technical safeguards for protecting the privacy and confidentiality of transmissions.

At the same time, the implementation of this solution—i.e. the actual elimination of E2EE—although it would undoubtedly reduce the level of protection available to the user, in many cases it would (unfortunately) bring it in line with the level of security offered in other types of services, e.g. voice services on 5G networks (based on the VoNR protocol).[28] If replacing full E2EE with transport encryption is indeed a far-reaching weakening of communication security, then this corresponds to the same weakening as in 5G technology, which is commonly referred to as secure [53], built with user data protection in mind [54] and the backbone of modern communication services [55].

An alternative to completely replacing E2EE with transport encryption is to implement both technologies simultaneously within a single application (communication protocol). Depending on the scope of information that the service provider would be required to collect, E2EE could be applied to part of the communication (e.g. its content), while transport encryption would protect other types of data. For example, the service provider could be required to monitor traffic in distribution groups with more than a specified number of participants (e.g. 50 or 100). Such a solution could be justified by the observation that such group chats function less as interpersonal communication and more as channels for distributing messages, similar to forums or social media.

In this type of model, therefore, it would not be so much a technical weakening of E2EE as a limitation of its scope of use. Mechanisms of this type are already in use today—an example here is Telegram, where E2EE is only available for interpersonal communication (1:1) and as an additional option (called Secret Chat).

Using third-party keys (key escrow)

Another proposal being considered to regulate (restrict) the use of E2EE is to actually weaken it rather than limit the scope of its use—i.e. to redesign communication protocols so that they offer a lower level of security from a technological point of view. The security of E2EE comes from third parties not having access to session keys, which are only known to the communicators. Session keys are agreed/transmitted using secure asymmetric cryptography algorithms. This means that the key is not sent by the sender to the recipient in plaintext,[29] but is encrypted with the recipient's public key.[30] As a result, only the recipient can determine the session key, which is then used for communication between users.

This mechanism can be modified by introducing mandatory encryption of the session key with the public key of a third party as well (so-called key escrow). This entity may be a service provider or a public authority [56]. Such a modification allows the external entity (e.g. law enforcement authorities) to decrypt the communication—in part or in whole—while still protecting the transmission against eavesdropping. Moreover, this mechanism can be applied so that even the service provider would not have access to the content of the message. In this model, only a public authority would have access to (decrypted) content data.[31]

At this stage, it should be noted that the concept of key escrow involves a crucial assumption that is often overlooked in the discussion, namely that the key of the trusted third party will not be compromised (e.g. by being disclosed in the public domain). Such a breach would allow the decryption of all communications from all users, including past transmissions (e.g. recorded in the form of ciphertexts). In other words, the key escrow model shifts the burden of trust in transmission security from the technology itself to a regulatory model.[32] Instead of trusting the maturity of the technology (and the computational correctness of cryptographic algorithms), in this scenario users must trust that third parties will not abuse the access to their transmissions and that the (legal) mechanisms regulating this access will be adequately secured, i.e. that the keys of public authorities will not be lost or stolen.

Theoretically, these weaknesses can be partially overcome, e.g. by introducing mechanisms for generating rotating certificates to be used by the public authorities or, in a more complex model, by requiring the interaction of several authorities in order to recreate a valid session key (e.g. one part of the private key could be held by a law enforcement authority and the other by a supervisory authority).[33] Although such solutions are possible and may even find practical application in some cases,[34] they seem to ignore the realities of mass and global communications services.

Narrowing down further considerations to only the four most popular messaging apps—WhatsApp, Facebook Messenger, Telegram, and Signal—the implementation of key escrow would require each provider to modify their E2EE solutions to encrypt user transmissions using dozens of different additional keys (assuming that only one authority would be made competent in a given Member State). Furthermore, it is difficult to see how Meta, for example, would determine which escrow keys to use for which transmissions. Would only the location of the communicators be taken into account, or also their nationality or the registered location of the service provider or the user, for example? This problem only increases when group chats are taken into account, in which it is not

[28] VoNR uses client–server–client encryption, where transmission is encrypted between the subscriber's device and the telecommunications operator's infrastructure.

[29] In this case, anyone eavesdropping on the transmission could intercept the session key and then use it to decrypt the main part of the communication.

[30] Or agreed upon in another way, e.g. using protocols such as Diffie–Hellman, where the session key is never actually transmitted (each party calculates it independently).

[31] This solution is technically complex, but feasible (it requires key escrow to be implemented as an external service to the provider). In this case, the main problem is not so much technical feasibility as a lack of transparency—and the resulting lack of public confidence that access to encrypted content is actually limited to the minimum necessary.

[32] This is not just a problem with the solution proposed for E2EE. It is worth remembering that the concept of key escrow is not new and was proposed many years ago as a mechanism for lawfully intercepting encrypted data [57].

[33] It is therefore a practical implementation of the concept of 'trust through decentralisation' [58].

[34] A typical example was the split-key scheme proposed by the NSA in the Clipper system (see [57]). A similar split-key model was used in the Data Recovery service in Microsoft EFS, which is an interesting example in that it concerned the encryption of stored data rather than transmitted data.

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

uncommon for dozens or even hundreds of people to communicate. This leads to the conclusion that the narrow exception which key escrow would entail—allowing a specific public authority to access selected data—would in practice lead to large-scale, excessive interference with users' privacy, without any clear reason or justification.

This uncontrollable excessiveness is the fundamental problem with key escrow. Proponents of this technique focus on demonstrating that it is technically feasible, but fail to explain why the communications of a Greek couple on holiday in Rome, for example, would be encrypted using a German, Polish, or Portuguese authority's key and, as a result, be (potentially) accessible to the public authorities of those states. The technical feasibility of an intervention does not determine its necessity and proportionality.

The proposals to implement key escrow presented in individual Member States, such as those (preliminarily) discussed in the UK (more on this later), essentially omit the issue of cross-border use of digital services. Therefore, even regardless of the assessed legitimacy of granting a public authority the ability to decrypt any traffic *en masse*, the proposal to implement key escrow simply does not stand up to the test of integrating it into the current way that global digital services operate.

Cloud backups

The controversy surrounding the use of third-party keys in the E2EE model prevents it from being used in democratic countries. Interestingly, at the same time, another scheme for accessing encrypted data is becoming increasingly widespread—one that is potentially just as effective for accessing transmitted messages without requiring any modification of the transmission encryption techniques. This involves accessing data stored in backups on the service provider's servers—whether they were created for the purposes of a specific (communications) service or are copies of the subscriber's entire device.

Communications applications typically offer the option of backing up data, including all conversations, sent messages, multimedia, etc. This functionality protects the user in the event of device failure and allows them to transfer their data when changing devices. Stored data, like transmitted data, can also be encrypted, but the exact method of protection depends on the service provider's design decisions.[35] Since accessing data stored on devices and in cloud services is a convenient way to obtain detailed information about communications, this option has been used by law enforcement agencies for years, leading to disputes and tension with service providers [59].

Providers rightly argue that giving law enforcement access to backups may be a way of circumventing the rules established to protect transmitted data and secrecy of communications. The provisions on electronic communications surveillance do not apply to accessing stored data, and in some cases (such as in the USA or, among EU countries, Poland), the procedures for accessing stored data are much less restrictive than those for wiretapping communications [60].

For this reason, some service providers, such as Apple, have modified their procedures for creating backups from subscribers' devices so as to limit (in theory, to prevent) access to this data without the user's involvement.[36] The data stored in the backup is encrypted with the user's key and requires the user's password to be viewed. Meta, on the other hand, has implemented a solution in WhatsApp that protects the content of WhatsApp conversations during device migration. This mechanism is built in a similar way to E2EE and offers a similar level of security (the provider cannot access the transferred data) [62]. Without going into the details of the solutions implemented by these companies, it is true that some other service providers, such as Telegram, do not provide transparent information on whether and how they secure copies of the communications stored on their servers.[37]

As in the case of transmission encryption, there are no common technical security standards for encrypting data stored on the provider's servers. Therefore, instead of introducing intrusive measures that weaken E2EE mechanisms, legislatures may consider creating a dedicated model for accessing data stored on service providers' servers. However, for such a solution to be effective, it would first and foremost entail the obligation to create such copies, which may lead to a discussion about the proportionality of this solution. In essence, a *mandatory* backup mechanism would cease to serve the function of protecting the user and would instead become a tool for controlling them. Furthermore, although such a measure—if properly implemented—could replace the need for state authorities to monitor transmitted data, it would not address one of the demands made by proponents of weakening E2EE, namely the ability to monitor transmissions in real time in order to identify instances of particularly harmful content being distributed.

Regardless of whether and to what extent access to stored data should be considered an appropriate replacement of obtaining transmission data, there is no doubt that when discussing transmission security (E2EE), the risks associated with inadequately protecting the same information stored on service providers' servers should also be taken into account.

Client-side scanning

The last form of interference discussed in relation to E2EE involves implementing data inspection directly on the subscriber's device. It is therefore a special form of accessing stored data, but unlike the case discussed above, it does not occur on the service provider's premises and therefore does not require data to be transferred to the provider's servers. The essence of client-side scanning (CSS) is to monitor user activity in a similar way to how this task is performed by antivirus software—that is in real time. While several years ago the use of such technology would have been complicated and in many cases impossible to fully implement (due to limited device performance and internet bandwidth), today the barriers are legal and regulatory rather than technical.[38]

In principle, CSS is a surveillance technique and should be assessed as such [65, paras 26–28]. It involves scanning content before it is published (sent) on an online service. Its functionality is similar to *upload filters*, but it is implemented in a distributed man-

[35] WhatsApp is a good example. The manufacturer provides detailed information on how transmitted data is protected and documents, which cryptographic protocols are used. At the same time, the user documentation does not state how the same data is protected/encrypted on the subscriber's device.

[36] This refers to the feature Advanced Data Protection for the service iCloud, implemented in 2022, which uses E2EE for data stored in backups [61].

[37] Available analyses indicate that "the bulk of correspondence is stored on servers in minimally encrypted form" [63].

[38] In reality, however, there are also technical controversies, leading to questions about whether CSS is technically feasible [64].

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

ner according to centrally managed rules. In this way, a communications service provider can, for example, exclude the transmission of known CSAM or terrorist content by blocking its transmission through the application (preventively eliminating it from the service). It does not require the technical capability to decrypt traffic to do this; in fact, the service provider need not even know that the user has attempted to do so.[39]

This means that CSAM content (and other known and legally unacceptable material) in this model can be eliminated from communications services without the need to weaken communication protocols and without the need for the service provider to collect information about what content has been identified and on which device [66]. In this sense, the technique can fulfil the need to monitor transmissions for serious violations of the law without actually weakening E2EE. However, this model does not fulfil another need reported by proponents, namely ensuring that the authorities have access to encrypted messages.

CSS is used to filter information, not to intercept communications. Of course, this model can also be used for that purpose, but then it would essentially function similarly to *spyware*. In such a case, the CSS functionality would have to be built into the device's operating system rather than a specific communications service. As a result, all of the user's online activity would be monitored, not only communications on a specific service. The disproportionate nature of this solution is so striking that it is difficult to imagine such a proposal being seriously considered as a regulatory strategy for digital services in democratic countries.

Therefore, the fundamental difficulty in implementing CSS is to present a (legal and technical) solution that would be flexible enough to effectively identify and block obviously illegal content, while incapable of being used for extralegal surveillance. Regulatory issues aside, this is a technically complex task and the risk of abuse is high [67]. From a technical point of view, the functionality of searching for obviously illegal content can very easily be used to identify any information, with the user having little (if any) control over the process.[40]

Regulatory responses

Before discussing possible—and recommended—EU legislative measures, it is also worth analysing how the discussion on the use of E2EE has progressed in other countries and what regulatory changes it has led to. The comparison will begin with the example of Russia, which is interesting because it is one of the few countries where extensive regulations targeting E2EE security have not only been implemented, but also assessed by an independent court—in this case, the European Court of Human Rights. The Court's reasoning can not only be applied to Russian law, but can also help set a standard for acceptable state interference in mechanisms that protect the confidentiality of user communications, such as E2EE. Next, we will discuss the proposals under consideration in the USA and the regulations implemented in the UK. Both examples are also relevant from the EU perspective, if only because both the USA and the UK are important trading partners of the EU, including in the digital market.

[39] As with key escrow, the main limitation of CSS is not technical capabilities, but the risk of abuse of power resulting from a lack of transparency in the use of this technique.

[40] In this regard, it is worth recalling the controversy surrounding the use of Kaspersky software for intelligence operations [68].

Russia

In 2016, the Russian authorities decided to adopt a controversial law that strengthens antiterrorism powers, better known as the Yarovaya Law [69]. One of its elements was extending the obligations of internet service providers (in legal terminology, "internet communications organizers") to areas, such as data retention and co-operation with law enforcement officers to ensure access to messages transmitted by users [70].

The Yarovaya Law introduced an obligation to retain metadata from electronic communications for 36 months and message contents for 6 months.[41] Apart from the long period of metadata retention, which *per se* raises serious doubts as to the compatibility of this measure with European standards [71, p. 39], the establishment of a general obligation to retain messages is noteworthy. In other words, the amended Russian regulations provided for permanent monitoring of all communications of all users of almost all means of electronic communication.[42]

It is worth recalling that, according to the EU Court of Justice's interpretation, such a measure not only goes beyond what is necessary in a democratic state, but also violates the essence of the right to privacy—and is therefore fundamentally incompatible with the values on which European democracies are built [73]. In this regard, the CJEU's position expresses a universal concept common to all democracies, according to which the state cannot permanently and systematically surveil the communications of the entire population simply because the material collected in this way may prove useful.[43]

As previously indicated, the mere imposition of a metadata retention obligation may require that an internet communications service be redesigned. If the application architecture provides for peer-to-peer communication—i.e. without the involvement of intermediary servers—the service provider will be unable to retain metadata, and may therefore encounter problems ensuring compliance with legal requirements. At the same time, however, the mere recording of metadata does not impose restrictions on the security of the information being transmitted. Therefore, retention requirements can also be met with full E2EE.

However, in order for the surveillance regime introduced by the Yarovaya Law to be complete, the legislature has established additional obligations that internet communications organizers must co-operate with law enforcement officers and ensure access to encrypted content.[44] These provisions have been widely interpreted as an actual ban on the use of E2EE in Russia, or an obligation to redesign the solutions in order to weaken encryption and allow state authorities to access communications.[45]

Formally, the Yarovaya Law does not impose any specific technique for weakening E2EE. Depending on the architecture of a

[41] Article 64(1) of the Communications Law (126-FZ) as amended by Article 13 of the Yarovaya Law.

[42] It should be noted that the Yarovaya Law was part of a larger process of creating the so-called RuNet, described by Russian authorities as related to building the state's digital sovereignty [72].

[43] A critical observer would see in this case a significant inconsistency, namely the tolerance in democratic states of extensive bulk electronic surveillance measures, which also operate preventively.

[44] This concerns the new Article 64(1.1) of the Communications Law added by the Yarovaya Law, according to which internet communications organisers are required "to provide authorized state bodies carrying out operational-search activities or ensuring the security of the Russian Federation with […] other information necessary for the performance of the task assigned to these bodies".

[45] This effect also resulted from the statutory obligation to store encryption keys used in Russia [74, para. 19].

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

given communications application, the service provider may, for example, decide to use key escrow or eliminate E2EE from its service altogether by replacing it with transport encryption. In any case, however, the legislature expected the providers to ensure that the relevant authorities could access the messages, and it imposed far-reaching sanctions, both financial and criminal, for any breach of this obligation [75].

It was precisely this aspect of the legislation that prompted one of Telegram's users to lodge a complaint with the ECtHR. The subject of the complaint was the obligation imposed on the messaging service provider Telegram Messenger LLP to provide the Russian Federal Security Service (FSB) with the information needed to decrypt the messages sent by users of the application. In proceedings before the domestic courts, the operator argued that the method of securing the transmission (E2EE) meant that not only did it not have access to the plaintext messages, but it also did not have the cryptographic keys (session keys) necessary to decrypt the messages.[46] The applicant, Anton Valeryevich Podchasov, argued that imposing an obligation on the service provider to weaken E2EE violated his right to privacy [77].

In assessing the case, the Court examined whether the measure of permanently reducing the security of users' communications met the test of necessity in a democratic state. In the circumstances of the case *Podchasov v. Russia*, the issue therefore concerned the manner in which the Secret Chats function was provided, which is the only service on Telegram that uses full E2EE. The service provider pointed out that the only way to make content available with this type of communication is to create a mechanism that limits the security of session keys—which in the court proceedings was referred to as the introduction of a backdoor [77, p. 8]. Although this element of the argument may seem overly technical, understanding it is key to assessing the accuracy of the Court's position. Both Telegram and, subsequently, the ECtHR recognized that obtaining the data requested by the FSB would require the service be redesigned by weakening E2EE. However, it is unclear how the introduction of key escrow technology in the new version of Telegram's application (which, as it should be understood, was referred to as "creating a backdoor") would help to decrypt historical data previously transmitted using the older application and other session keys.

However, this inaccuracy was not noticed by the Court, which focused on assessing the proportionality of introducing a permanent measure that would weaken the security mechanisms available to all users solely for the purpose of gaining access to certain messages. Against this background, it found that "these measures allegedly cannot be limited to specific individuals and would affect everyone indiscriminately, including individuals who pose no threat to a legitimate government interest" [77, p. 77] Furthermore, in the Court's view, such a solution would also create a serious risk of abuse of power, as it would "make it technically possible to perform routine, general, and indiscriminate surveillance of personal electronic communications."

As a result, the ECtHR found that the solution introduced in the Yarovaya Law—obliging service providers to co-operate with public authorities by providing them access to encrypted content, including to the extent that this would require the deliberate weakening of the security of the products created—goes beyond what can be considered necessary in a democratic state [77, p. 79].

[46] For more on the dispute between Telegram and the Russian authorities, see [76].

Although the Yarovaya Law ruling is commonly presented as determining that measures weakening E2EE (key escrow in particular) are incompatible with the European Convention on Human Rights [78], it appears that this assessment is incomplete. The Court's ruling should be read in the context of the particular case. The Yarovaya Law introduces far-reaching interference with individual rights, going well beyond the standards adopted in democratic countries. However, the Yarovaya Law ruling does not contain a clear standard of the Court to assess the limits of state interference in encrypted traffic. The disproportionate nature of the Russian variant of key escrow lies in its unlimited application (to all users and without effective external oversight). But what if key escrow were used under court supervision and only in relation to certain users (covered by a surveillance order)? The position on the disproportionate nature of ordering a service provider to create a backdoor is also somewhat unclear. It is worth contrasting it with the extensive case law of the courts (including the CJEU) on the use of EncroChat [79], which was in fact a backdoor created on the initiative of public authorities and implemented on a previously unknown scale [80–82].

It is worth noting that the dispute resolved in *Podchasov v. Russia* concerns only a small portion of transmissions carried out using Telegram. As mentioned above, E2EE is not the default form of transmission protection in this application, and it is generally used by only a small portion of users. All other messages are transmitted using transport encryption, which is the default setting in this application. Since the use of E2EE in Telegram requires specific actions from the user, it should be expected that this method of transmission protection would be consciously chosen by those concerned. Content sent by all other users (and all messages exchanged in group chats) is accessible to the service provider and, in light of the Yarovaya Law, also to Russian law enforcement agencies and security services.

USA

The admissibility of restrictions on the use of encrypted traffic—and more broadly, access to encrypted communications—has also been debated for years in the United States. First and foremost, attention is drawn to attempts to oblige service providers to deliberately weaken security measures in order to gain access to stored digital data.

Federal law distinguishes between legal safeguards applied in the context of wiretapping and those applied in order to access stored data. In the latter case, fundamental restrictions were introduced by the Stored Communications Act [83]. This act is important because without it, stored data would not be protected from public authorities at all [84]. This is because the US Constitution does not define a broad right to privacy, as is the case in Europe countries, but instead offers guarantees against unlawful search and seizure. However, according to the third-party doctrine [85], these guarantees do not apply to information that the user has knowingly provided to another entity (e.g. a service provider). Therefore, although the Fourth Amendment requires prior court approval to access electronic data stored in a user's home or on a user's device, the procedure did not apply to data stored on a service provider's servers [86]. This led to controversy as to whether and to what extent service providers could be legally required to assist in decrypting the data in their possession. In the context of federal criminal law, the ques-

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

tion essentially concerns whether the issuance of such an order can be simplified or whether it requires prior court approval, as in cases of search (covered by the Fourth Amendment to the Constitution).

However, even when the data collected is covered by constitutional guarantees—e.g. it is stored on phones seized by law enforcement agencies—the problem of accessing encrypted data arises. This was the case in a series of orders that Apple received in 2016, in which it was required to grant the Federal Bureau of Investigation (FBI) access to encrypted data stored on the iPhones of individuals suspected of being involved in the planning of terrorist acts [87]. In this case, law enforcement authorities had secured the devices and gained court approval to access the data, but the data was encrypted. The legal issue that arose was whether and how a service provider could be required to deliberately weaken its technology in order to gain access to data. In this case, the FBI sought to compel Apple to create a special version of its operating system that would be installed on the suspects' devices and ultimately allow access to the information stored on them [88].

Apple challenged the orders it received, noting procedural errors as well as the fact that the obligation to introduce a security flaw into its own products creates a risk of abuse of power and jeopardizes the security of all users. The supplier pointed out that the order imposed a far-reaching solution that was disproportionate and therefore unnecessary, as there were less invasive ways of obtaining the requested information [89].

The dispute was not ultimately resolved on its merits at that time—the FBI withdrew its demands. It is likely (although this has not been officially confirmed) that the Bureau gained access to requested data using spyware tools (exploiting zero-day vulnerabilities in the operating system) [90]. However, this case was the first to draw the general public's attention to the problem of law enforcement agencies accessing encrypted data [91].

Although the Apple case did not appear to involve the weakening E2EE, in reality, this was precisely the solution that the FBI wanted. The public authority demanded the introduction of a permanent restriction in a technological product that would implement (in a modified way) the concept of key escrow—leading not so much to the weakening of encryption during transmission, but to the encryption of data stored on devices.

The legal solution directly targeting the security of transmitted data was the EARN IT bill, presented in 2020 [92]. Unlike the Russian Yarovaya Law, however, EARN IT did not introduce a model of mandatory (compulsory) cooperation between service providers and law enforcement agencies, nor did it introduce any specific solutions to weaken E2EE. The aim of EARN IT was to link the actions taken by service providers to the scope of immunity granted to them by federal law with regard to content transmitted by third parties (including users).

Under Section 230 of the Communications Act of 1934 (introduced by the Communications Decency Act), service providers—as internet intermediaries—are not treated as the authors or publishers of content that is transmitted using their services. The immunity under Section 230 is very broad and largely excludes the possibility of holding service providers liable for the dissemination of illegal content [93]. Unlike in EU law, under federal law, the limitation of internet intermediaries' liability is not linked to their passive behavior or lack of knowledge of the illegality of the content being disseminated. Section 230 also has a very broad scope, which is not limited to hosting service providers, as is the case with similar solutions in the EU.

Regardless of the actual significance of Section 230 in federal law, this immunity is not absolute [94]. In particular, it does not exempt providers from liability for violations of other federal laws, including those related to combating crimes against children. A service provider who has knowledge of and knowingly participates in the transmission of CSAM not only cannot benefit from the exemption provided for in Section 230, but may also be held criminally liable for their actions (or wilful omission) [95].

The essence of EARN IT was to link the scope of Section 230 to the detection of CSAM in encrypted communications. The bill did not provide for restrictions on the use of E2EE or obligations related to active content scanning *per se*, though it did include the possibility of a public body appointed for this purpose to adopt best practices. Failure to comply with these standards could, in turn, result in the provider being unable to invoke Section 230 immunity in relation to detected cases of CSAM [96]. In essence, these best practices would be a key document defining the limits of service providers' interference in encrypted traffic. Watchdog organizations have pointed out that such a measure could be used to introduce intrusive forms of control, such as CSS, with the intention of identifying and blocking CSAM [97].

In reality, the EARN IT Act was intended not so much as a tool to directly restrict E2EE, but as a means of creating a framework for the legal regulation of the use of modern digital services. What was interesting and certainly noteworthy about this proposal was the nature of the proposed regulatory model, which was not based on financial or criminal sanctions, but on clarifying the safe harbour regulations established for internet intermediaries.

UK

While the case *Apple v. FBI* focused on access to data stored on devices, a similar dispute concerning the encryption of backups on service providers' servers took place in the UK. In 2025, the media reported on the British Home Office's issuance of a Technical Capability Notice (TCN), [47] which required Apple to create a technical capability that enables access to data stored under the Advanced Data Protection (ADP) feature [98]. The purpose of the TCN was to create a backdoor, with functionality similar to key escrow, that would allow law enforcement agencies to access encrypted data stored by users in Apple's cloud. Importantly, neither the content nor the manner of implementation of the TCN are publicly known.[48] However, recognizing the threat of a permanent reduction in the security of its service, the service provider decided to discontinue ADP on the UK market [100]. This means that data stored by new British Apple users will not be protected by E2EE in the same way that this mechanism works in all other markets where it is offered [101].

Controversy over the use of TCN to weaken the security of stored data also influenced the debate on the draft of a new bill to combat online hate speech, ultimately adopted as the Online Safety Act of 2023 (OSA). Work on this regulation took more than 5 years, during which the issue of the admissibility of restrictions on encrypted traffic was also examined [102]. In the British legal model, the OSA was intended to supplement existing provisions on the liability of service providers for illegal content and harm-

[47] See Section 253(5) of the Investigatory Powers Act 2016.
[48] For a more detailed description of the TCN measure, see [99].

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

ful speech.[49] One of the objectives of the Act was to increase the protection of children from not only illegal content, but also harmful content.[50] Unlike EU law (e.g. the Digital Services Act), the OSA covers communications services as well as hosting services. As a result, the legal instruments established therein apply to a wider range of digital services than similar measures applied in EU law.

The OSA promotes a model of responsibility based on systematic risk management. Instead of setting strict procedures and imposing specific measures on service providers, it requires security measures to be adapted to the risk profile affecting users, taking into account the specific nature of the service in question [105]. By introducing a general liability regime, the OSA also establishes specific administrative measures that can then be used to clarify professional standards and the rules of liability for internet intermediaries. The Act allows the regulatory authority (Ofcom) to issue detailed technical standards (technology notices) for service providers that are applicable to both specific services and types of infringements. As the first standards of this type, Ofcom has published draft regulations on combating CSAM and terrorist content [106].

The need to introduce broad powers for Ofcom in the Act has been questioned from the outset, as the OSA *per se* does not exclude the possibility of imposing obligations on service providers related to use of E2EE [107]. Some service providers even announced that they would withdraw from the UK market if the new regulations required mechanisms that would weaken E2EE security [108]. The government responded to the criticism by announcing that the OSA would not be used to introduce permanent restrictions on the security of encrypted communications [109]. This position was also reiterated by Ofcom [110].

The OSA essentially combines certain elements of the Yarovaya Law (the obligation to cooperate with law enforcement authorities) and the EARN-IT Act (the lack of strict measures that service providers are required to implement). At the same time, the solution differs from both the Russian regulation (the OSA does not require *per se* the weakening of encryption) and the American proposals (unlike EARN IT, it does not focus on only one category of violations, i.e. CSAM). Suffice it to say that, despite the two years since the Act came into force, leading E2EE-based communications service providers continue to offer their services on the British market. There are also no reports that the government intends to use its powers under the OSA to implement measures that would limit the security of encrypted communications.

Possible scenarios for the EU

The debate on the importance of communication confidentiality and the risks associated with it has also been the focus of attention for both EU institutions and individual Member States for years. Particular attention is being paid to increasingly frequent reports of criminal groups communicating through encrypted messages [111] and of abuses of power in the use of surveillance measures.[51]

An example of this is the ongoing discussion concerning the draft of the new EU CSAM Regulation.[52] This act is intended to replace the so-called Interim Regulation [113], which was adopted in 2021 to enable providers of certain communications services to voluntarily use communication monitoring techniques to identify CSAM. The Interim Regulation achieves this objective by introducing an—unprecedented in EU law—exemption from certain guarantees related to the privacy of communications. For this reason, the regulatory model introduced by this regulation has been rightly criticised by both watchdog organisations and the EDPS [114].

Although the Interim Regulation creates a framework for monitoring transmitted messages (automatic scanning them), it does not per se establish any obligations in this regard—including the use or non-use of E2EE. The Regulation describes voluntary measures—those that a provider *may* take, but is *not required* to take—and failure to apply them does not lead to any negative consequences that may be imposed on the provider.

The Interim Regulation was presented as a temporary measure, applicable until a more comprehensive legal regulation could be developed. The target legal instrument is the draft CSAM Regulation of 2022. Unlike the Interim Regulation, this draft defines a regulatory model based not on voluntary measures, but on specific legal obligations—addressed to a wider group of entities. Therefore, while the Interim Regulation is applied only to a narrow group of electronic communications service providers (mainly instant messaging providers), the draft CSAM Regulation also covers hosting service providers and ISPs.

However, the draft regulation is widely perceived as being mainly associated with the so-called "chat control" mechanism, i.e. the provisions on scanning encrypted communications. The original draft of the act did not contain explicit regulations concerning an obligation to inspect encrypted communications. However, it introduced a framework for issuing so-called detection orders,[53] which, in the opinion of watchdog organizations, could constitute a mechanism for restricting encrypted traffic, e.g. by ordering service providers to use CSS or key escrow mechanisms.[54] Both the instrument of detection orders and the doubts associated with it closely resemble the arguments put forward in relation to similar measures used (or considered for use) in the USA and the UK.

Given the perspective of human rights system, which is firmly rooted in EU law, the introduction of measures severely restricting E2EE would not only be difficult, but almost certainly impossible (legally ineffective). Apart from the relationship between the draft CSAM Regulation and other EU secondary law legislation, the legislature cannot derogate from EU primary law—and thus from the guarantees provided for in the Charter of Fundamental Rights. Moreover, the proposed act's broad scope of application may raise doubts as to whether and to what extent the regulation—by requiring the use of mechanisms to identify CSAM content—would violate one of the foundations of EU digital law, namely the prohibition against establishing a general monitoring obligation [115].

In order to reduce these ambiguities and eliminate interpretative doubts, subsequent drafts of the act specified that the inter-

[49] This mainly concerns the concept of "grossly offensive" speech, introduced in Section 127 of the Communications Act 2003 [103].

[50] In this context, the UK Government pointed to the need to regulate E2EE traffic [104].

[51] In recent years, this issue has been mainly associated with abuses of targeted measures, including the so-called PegasusGate [112].

[52] The most recent draft regulation, presented by the Danish Presidency on 24 July 2025, is available on https://cli.re/aE8Vz2; accessed 26 August 2025.

[53] This mechanism is still present in the draft regulation—see n 52, Art. 10(1).

[54] Article 10(1) in the version proposed by the Danish Presidency indicates the possibility of implementing CSS.

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

pretation of the regulation must not lead to a weakening of E2EE[55] or a violation of the prohibition of the general monitoring obligation.[56] Assuming that this wording of the provisions will ultimately be adopted, this would strengthen EU guarantees that prohibit the weakening of E2EE by *explicitly* including them in a statutory act.

However, it is worth looking at the issue of regulatory policy on encrypted traffic more broadly, rather than solely as maintaining the current status quo. First, although the draft CSAM Regulation has a broad subjective scope, it concerns the fight against one type of infringement. This means that the discussion on whether or not to weaken encrypted communications in this case refers exclusively to one category of content (CSAM). Assuming—purely hypothetically, and ignoring the related technical problems—that Microsoft or Google would be legally obliged to inspect encrypted traffic, it seems clear that this measure would affect the security of all communications, not just those related in any way to child safety. Similarly, if the EU legislature were then to adopt a law requiring the scanning of encrypted correspondence to identify cases of human trafficking, the application of this (hypothetical) sectoral act would *de facto* open the door to weakening E2EE in all communications, thus rendering the prohibitions introduced in the CSAM Regulation useless.[57]

Therefore, prohibiting the introduction of techniques that weaken E2EE would only have real systemic significance if such a ban were included in a horizontal act rather than a sectoral one. The proposed Article 1(5) of the draft CSAM Regulation, according to which no provision of the Regulation may be interpreted as requiring the restriction of communication security techniques (including E2EE), should not be introduced into a sectoral act, but into a horizontal act—in this case, an act on e-privacy in electronic communications.

Given the current framework for telecommunications regulation, this new regulation should adopt the conceptual framework already employed in EU law, particularly in the EECC Directive, the e-Privacy Directive, and the Digital Services Act. The scope of such an act should extend beyond—and certainly should not be limited to—procedures governing access to encrypted data, and should instead address the normative relationship between the cryptographic protection of communications and the fundamental rights guaranteed by the Charter. In particular, the regulation could establish:

- A definition of the "right to encryption," positioning it as an accompanying right to the right to privacy and the confidentiality of communications.[58]
- The scope and subject matter of this right, focusing on communication services (i.e. interpersonal communication[59]) rather than services for distributing online communication.
- Minimum standards for the protection of communications, including an obligation to ensure transparency regarding service providers' activities (e.g. publishing information on the cryptographic mechanisms being used), and for the promotion of open cryptographic standards.
- Positive obligations for service providers, such as ensuring that users have effective access to E2EE functions, and introducing the principle of "encryption by default," modeled on similar solutions used in data protection law [116]; this would also entail prohibiting the use of techniques that deliberately weaken encryption mechanisms, such as hidden backdoors.
- Conditions and procedures for traffic inspection, with distinct regimes for monitoring group communications (for example, communications addressed to more than 20 recipients).

In this context, the restrictions and guarantees would affect large part of digital services, including also electronic communications services, thereby strengthening individual rights, regardless of any *lex specialis* provisions that might be adopted in future. Thus, even if the EU legislature decided to extend the (also controversial) Terrorism Content Regulation with new (hypothetical) measures to control encrypted traffic, for example, these instruments would have to comply with the proposed horizontal (framework) regulation.

Of course, critics of such a solution may (not without reason) point out that the EU legislature can easily deviate in *lex specialis* regulation from the application of the general rules that it has previously established. In this sense, the new sectoral regulations would not be a sufficient safeguard, as they would form part of secondary law in the hierarchy of EU law and could therefore, in principle, be amended relatively easily.

However, this is an overly pessimistic assessment. Experience shows that EU framework regulations, especially those concerning fundamental rights, lay the foundations for EU law and have a strong influence on the direction of further regulations in a given area. This was the case with regulations on personal data protection,[60] as well as with regulations on electronic communications and cybersecurity and intermediary liability in digital markets [119]. In each of these cases, the actions of both the EU legislature and the CJEU over the years have led to an increase in the actual significance of the rights and guarantees arising from these horizontal regulations.

Furthermore, adopting a new horizontal act would provide an opportunity to create legal framework which, following the example of other EU regulations, could initiate the Brussels effect [120], i.e. the transfer of similar solutions to other legal models. This would give the EU a unique opportunity to standardize the issue of accessing E2EE data comprehensively and perhaps even globally, not only at the local level and in relation to a single category of cases (CSAM).

However, the fundamental problem with implementing this proposal is that the only horizontal act currently covering this area is Directive 2002/58 [121], which is over 20 years old. Moreover, the European Commission announced in 2025 that it would withdraw the draft regulation intended to replace this directive from further legislative work [122 at 26]. Directive 2002/58 is an archaic act in the sense that it was created before the era of widespread digitisation and, despite the 2009 update, does not meet the needs and challenges of today. It is unreasonable to expect that this act

[55] See n 52, Art. 1(5).

[56] *Ib*id., recital (31)

[57] This problem is presented in a simplified manner. In reality, bearing in mind the concept of *effet utile*, the result would probably be a dispute requiring the CJEU to interpret how to reconcile the application of both legal acts.

[58] In this regard, the concept of a "right to privacy" does not need to be explicitly mentioned in the text of the proposed regulation; it can be understood as a set of regulatory requirements that are not accompanied by an independent subjective right (similar to the "right to the open internet", which is also not explicitly mentioned in Regulation 2015/2120).

[59] See the definition of interpersonal communication services introduced in Article 2(5) EECC Directive.

[60] For over 20 years, Directive 95/46 shaped not only the EU legal model, but also the evolution of data protection regulations in third countries. It is currently suggested that the GDPR performs a similar function [117,118].

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

will be supplemented with detailed solutions that exclude interference with encrypted traffic.

Assessing the outcome of the European discussion on "Chat Control," it is also clear that, so far, it has not led to a deeper reflection on the legal essence of regulating the cryptographic protection of communications. The comparison presented in this article shows that today it is service providers, who essentially decide how to protect user transmissions, including whether this protection excludes eavesdropping or interference by third parties. There is no reason why a legislature, when establishing prohibitions on the deliberate weakening of E2EE, should not at the same time address the issue of requiring E2EE in (certain) communications services or adopting standards for cryptographic protocols to be used. If, in the opinion of the EU legislature, E2EE is such an important mechanism that its weakening should be counteracted, it is difficult to understand why there are no regulations requiring its use in the first place.

The fundamental problem with both the draft EU CSAM Regulation and, more broadly, the European debate on protecting encrypted transmissions is their introduction of unnecessary generalizations which, instead of simplifying the regulatory model, ultimately create a fiction that will not stand up to the reality of global digital services. The adoption of the EU CSAM Regulation will result in only a kind of *declaratory* protection of E2EE communications.

Its prohibitions are only binding on the authorities of Member States and have no impact on actions taken by third countries. It should be remembered that most communications services are provided by entities based outside the EU (Meta, Google, Microsoft, Telegram, TikTok, etc.). This means that although these entities cannot be required to restrict E2EE as a result of actions taken by Member State authorities, under the proposed wording of the CSAM Regulation they may introduce such restrictions on their own initiative or as a result of an order received from a third country. As a result, it will be the US or Chinese government that will decide whether and to what extent Europeans' communications are protected, which does not seem to contribute to the EU's concept of building a secure, sovereign digital services market.

There are also no obstacles to developing mechanisms to cryptographically protect communications, which will be transparent and based on recognized technical standards and will meet the needs of various stakeholders. In this regard, it is worth noting the project carried out by the British government as part of its work on the implementation of the OSA, which presented and discussed various proposals for increasing the surveillance of encrypted traffic without violating the fundamental principles of communication secrecy [123]. Solutions which could be transposed to the EU include more clearly distinguishing between communications services and hosting services, which would translate into the applicable regulatory policy. It seems reasonable to legally restrict communication products from offering functionalities characteristic of social media (large distribution groups). The law should prioritise ensuring secure communication—free from surveillance, including by the service provider—in communications services.

The use of E2EE does not prevent the traceability of users, which is already possible and used in many communications services today (with the difference being that this data is currently collected and used mainly for the economic interests of the service provider). An effective regulatory strategy could be to create a reliable (and transparent) transmission encryption scheme, assuming that, for example, attachments distributed to large groups of users (e.g. more than 20 people) will be protected using transport encryption rather than E2EE. This solution would not restrict E2EE for message content but would apply only to selected attachments, which could then be analysed and compared with a database of known illegal content. In this case, from a technical point of view, the same application would use both E2EE and transport encryption—not at the discretion of the service provider, but in accordance with approved standards developed by public authorities in consultation with stakeholders.

This proposal could also be further refined, for example by introducing measures that increase the reliability of the techniques used to identify unlawful content on hosting services [124]. Today, this area is essentially monopolized by tools created and managed by private entities, with almost no participation from public entities. As a result, private entities identify CSAM according to a reference database that they themselves create or obtain from other private entities [125].

Unfortunately, the current legislative work in the EU does not explore any of the proposed regulatory approaches. Not only are they focused exclusively on one category of content, but even in this regard, they should be considered very conservative and fragmentary. They leave service providers with a great deal of discretion, which means that the "right to encrypt" becomes "the right of service providers to encrypt as they see fit."

Therefore, if the EU really wants to strengthen the protection of users' privacy against new forms of threats, it should first seek to develop a horizontal act that would establish not only prohibitions, but also obligations regarding the standards of cryptographic protection of digital services, and should do so in a balanced manner that takes into account both the need to ensure confidential communications and general security objectives.

Conclusion

In today's digital services, the term "end-to-end encryption" is used to describe a whole set of technical solutions, some of which have little to do with actual E2EE. Clarifying the terminology makes it easier to see that the long-signaled problem of encrypted communications being used in criminal activity not only exists and is serious, but can also be (at least partially) solved without undermining the foundations of E2EE. Furthermore, a better understanding of how technical data encryption measures work can also allow for a more comprehensive view of the security of the entire ecosystem of modern digital services—in which the same data that is first transmitted using secure communication channels is often stored by service providers in unencrypted form (or with encryption of unknown quality), sometimes on servers located in foreign jurisdictions.

Although the public debate focuses mainly on the risks associated with the introduction of key escrow, there are other methods that can effectively weaken the security of user communications. Importantly, in some cases, these solutions do not entail any interference with the communication protocols being used. This observation proves that when examining the importance of communication encryption for the protection of users' rights, one should not focus solely on the transmission protocols, but should also pay attention to the flow of protected information and the places where this information should be secured.

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

Interestingly, the debate on E2EE regulation also largely ignores the developments in the digital market. In all regulatory models and in all strategies to weaken E2EE, a key role is assigned to the service provider. Meanwhile, in recent years, decentralised services (DLT) have been gradually gaining popularity, as they do not require a central node (service provider server). Although most attention focuses on applications in the financial sector (DeFi) [126], there are also decentralized implementations of communication services [127] and social media [128,129]. In the case of decentralized services, there is no "service provider" in the traditional sense actively managing how the service is provided. This function may be partially performed by the developer of the software/communication protocol, but even in this case, DLT services are frequently based on open-source solutions in which the user community is an important driver of development [130].

Overly radical regulatory interference with E2EE may not only lead to serious legal concerns, but also become an impetus for the development of decentralized services—as a result, it may distort competition in the digital services market and create space for the unrestricted distribution of illegal content [131]. Above all, however, a reasonable legislature, when establishing rules governing the use of encrypted communications, should ensure that they have a proportionate impact on the entire market, and not just on the part of it that is easy to regulate.

There is no doubt that regardless of the future of the EU CSAM Regulation, the risk of introducing far-reaching restrictions on the use of E2EE technology will not disappear. The controversy surrounding the measures proposed in the Regulation only confirms that this issue requires horizontal regulation of the entire digital services market to be comprehensively addressed. The EU CSAM Regulation was not intended to be and will not be such a regulation; the safeguards it contains will have a limited impact on the rules for global service providers' use of E2EE. Only a horizontal act will make it possible to establish a comprehensive, coherent model for regulating cryptographic techniques (not limited to E2EE) in modern digital services—including communications, hosting and social media. Moreover, such an act, if adopted, would also strengthen users' rights and the obligations of all stakeholders to respect them—both public authorities and private actors, including service providers.

Author contributions

Marcin Rojszczak (Conceptualization [lead]; Investigation [lead]; Methodology [lead]; Writing – original draft [lead]; Writing – review & editing [lead]).

Conflicts of interest

None declared.

Funding

This work was supported by the National Science Centre, Poland (grant number 2023/51/D/HS5/00639).

References

1. Commission, Proposal for a Regulation of the European Parliament and of the Council laying down rules to prevent and combat child sexual abuse (COM 2022 209 final, 11 May 2022) [Draft EU CSAM Regulation].
2. Directive (EU) 2018/1972 of the European Parliament and of the Council of 11 December 2018 establishing the European Electronic Communications Code (Recast) [2018]OJ L321/36.
3. Rojszczak M. OTT regulation framework in the context of CJEU Skype case and European Electronic Communications Code. *Comput Law Secur Rev* 2020;**38**:105439. https://doi.org/10.1016/j.clsr.2020.105439
4. WhatsApp. How to create and invite into a group. WhatsApp Help Centre. https://cli.re/EvRjwr (16 July 2025, date last accessed).
5. Telegram. General questions. https://telegram.org/faq#general-questions (22 August 2025, date last accessed).
6. Milczarek E. Preventive content blocking and freedom of expression in the European law—conflict or symbiosis? *J Media Law* 2021;**13**:262–75. https://doi.org/10.1080/17577632.2021.2006962
7. *Delfi AS v Estonia* App no 64569/09 (ECtHR, 16 June 2015).
8. *Sánchez v France* App no 45581/15 (ECtHR, 15 May 2023).
9. Mchangama J, Alkiviadou N. Hate speech and the European Court of Human Rights: whatever happened to the right to offend, shock or disturb? *Human Rights Law Rev* 2021;**21**:1008–42. https://doi.org/10.1093/hrlr/ngab015
10. Sottiaux S. Conflicting conceptions of hate speech in the ECtHR's case law. *German Law J* 2022;**23**:1193–211. https://doi.org/10.1017/glj.2022.81
11. *Frank Peterson v Google LLC and Others*; *Elsevier Inc v Cyando AG* (Joined Cases C-682/18 and C-683/18) (CJEU, Grand Chamber, 22 June 2021) EU:C:2021:503.
12. *Republic of Poland v European Parliament and Council of the European Union* (C-401/19) EU:C:2022:297.
13. Rojszczak M. Gone in 60 minutes: distribution of terrorist content and free speech in the European Union. *Democr Secur* 2024;**20**:179–209. https://doi.org/10.1080/17419166.2023.2250731
14. Macnish K. An end to encryption? Surveillance and proportionality in the crypto-wars. In: A Henschke, A Reed, S Robbins (eds), *et al.* (eds), *Counter-Terrorism, Ethics and Technology, Advanced Sciences and Technologies for Security Applications*. Cham: Springer International Publishing, 2021,155–73. https://doi.org/10.1007/978-3-030-90221-6_10
15. Privacy International. Securing privacy: pi on end-to-end encryption. London, 2022. https://cli.re/Mjjw8n (26 November 2025, date last accessed).
16. European Parliamentary Research Service. E2E encryption and protection of children online. Paris, 2023. https://cli.re/d7ZNwp (26 November 2025, date last accessed).
17. Chin M. Zoom isn't actually end-to-end encrypted. The Verge, 2020. https://www.theverge.com/2020/3/31/21201234/zoom-end-to-end-encryption-video-chats-meetings *(22 August 2025, date last accessed).*
18. Miller S, Bossomaier T. Privacy and confidentiality: bulk data, surveillance, and encryption. In: *Cybersecurity, Ethics,*

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

and Collective Responsibility. Oxford: Oxford University Press, 2024. https://doi.org/10.1093/oso/9780190058135.003.0003
19. Bos JW, Stam M (eds). *Computational Cryptography: Algorithmic Aspects of Cryptology*. London Mathematical Society Lecture Note Series, 469. Cambridge, New York: Cambridge University Press, 2021. https://doi.org/10.1017/9781108795937
20. Miculan M, Vitacolonna N. Automated verification of Telegram's MTProto 2.0 in the symbolic model. *Comput Secur* 2023;**126**:103072. https://doi.org/10.1016/j.cose.2022.103072
21. Rastogi N, Hendler J. WhatsApp security and role of metadata in preserving privacy. *arXiv* 2017. https://arxiv.org/abs/1701.06817 (26 November 2025, date last accessed).
22. Cohn-Gordon K, Cremers C, Dowling B *et al.* A formal security analysis of the signal messaging protocol. In: *Proceedings of the 2017 IEEE European Symposium on Security and Privacy (EuroS&P)*. Piscataway, NJ: IEEE, 2017, 451–66. https://doi.org/10.1109/EuroSP.2017.27
23. Telegram. FAQ: so how do you encrypt data?. https://telegram.org/faq#q-so-how-do-you-encrypt-data (22 August 2025, date last accessed).
24. Telegram API. Telegram API. End-to-end encryption, secret chats. https://core.telegram.org/api/end-to-end (22 August 2025, date last accessed).
25. Rojszczak M. National security in a digital Europe. *Eur Law Rev* 2023;**48**:545–67.
26. Griffin A. WhatsApp should be shut down if it doesn't deal with paedophiles, says Amber Rudd. The Independent, 2017. https://cli.re/Za5vrP (22 August 2025, date last accessed).
27. Internet Watch Foundation. Preventing the upload of child sexual abuse material (CSAM) in E2EE environments. Cambridge, 2025. https://www.iwf.org.uk/media/21rpo2o4/iwf-preventing-the-upload-of-child-sexual-abuse-material-in-end-to-end-encrypted-e2ee-environments-v1.pdf (20 October 2025, date last accessed).
28. Directive (EU) 2019/790 of the European Parliament and of the Council of 17 April 2019 on copyright and related rights in the Digital Single Market and amending Directives 96/9/EC and 2001/29/EC [2019]OJ L130/92.
29. Romero Moreno F. 'Upload filters' and human rights: implementing Article 17 of the Directive on Copyright in the Digital Single Market. *Int Rev Law Comput Technol* 2020;**34**:153–82. https://doi.org/10.1080/13600869.2020.1733760
30. Sartor G, Loreggia A. The impact of algorithms for online content filtering or moderation. *Upload Filters, PE 657.101*. Brussels: European Parliament, 2020, 72. https://cli.re/VaRqpm (1 July 2025, date last accessed).
31. Hartel P, Van Wegberg R. Going dark? Analysing the impact of end-to-end encryption on the outcome of Dutch criminal court cases. *Crime Sci* 2023;**12**:5. https://doi.org/10.1186/s40163-023-00185-4
32. Europol. European Police Chiefs call for industry and governments to take action against end-to-end encryption roll-out. 2022. https://cli.re/r8XY5X (22 August 2025, date last accessed).
33. Birnbaum E. Barr warns encryption allows "criminals to operate with impunity". The Hill, 2019. https://cli.re/7ZDxo1 (22 August 2025, date last accessed).
34. Ullrich C. Unlawful content online: towards a new regulatory framework for online platforms. In: *Luxemburger Juristische Studien*. Vol. **21**. Baden-Baden: Nomos, 2021. https://doi.org/10.5771/9783748927051
35. Ghoshal A. UK Home Secretary embarrassingly ignorant: "I don't need to understand how encryption works". The Next Web, 2017. https://cli.re/m8zzZR (22 August 2025, date last accessed).
36. EDRi. Statement on the future of the CSA regulation. 2024. https://edri.org/wp-content/uploads/2024/07/Statement_-The-future-of-the-CSA-Regulation.pdf (22 August 2025, date last accessed).
37. Bitkom. Statement on chat control and the right to encryption. 2022. https://cli.re/xyJe8Y (22 August 2025, date last accessed).
38. van Daalen OL, 'The right to encryption: privacy as preventing unlawful access.' *Comput Law Secur Rev* 2023;**49**:105804.
39. Gesellschaft für Freiheitsrechte (GFF). Chat control: incompatible with fundamental rights. Berlin. https://freiheitsrechte.org/en/themen/digitale-grundrechte/chatkontrolle (22 August 2025, date last accessed).
40. Kokott J, Sobotta C. The distinction between privacy and data protection in the jurisprudence of the CJEU and the ECtHR. *Int Data Priv Law* 2013;**3**:222–8. https://doi.org/10.1093/idpl/ipt017
41. Brkan M. The essence of the fundamental rights to privacy and data protection: finding the way through the maze of the CJEU's constitutional reasoning. *German Law J* 2019;**20**:864–83. https://doi.org/10.1017/glj.2019.66
42. CEPIS. Open letter against planned EU chat control. 2022. https://cepis.org/open-letter-against-planned-eu-chat-control/ (22 August 2025, date last accessed).
43. Landau SE. *Surveillance or Security?: The Risks Posed by New Wiretapping Technologies*. Cambridge: MIT Press, 2013.
44. Federal Bureau of Investigation. Lawful access to secure messaging apps data. Washington, 2021. https://propertyofthepeople.org/document-detail/?doc-id=21114562 (22 August 2025, date last accessed).
45. Signal. Technology preview: sealed sender for Signal. 2018. https://signal.org/blog/sealed-sender/ (22 August 2025, date last accessed).
46. Kamakoti V. Report of Prof. V. Kamakoti in WP Nos. 20214 and 20774 of 2018. Chennai: Madras High Court, 2018. https://cli.re/XamabM (22 August 2025, date last accessed).
47. Indian Journal of Law and Technology. Analysing the technical workarounds to end-to-end encryption. 2021. https://www.ijlt.in/post/analysing-the-technical-workarounds-to-end-to-end-encryption (22 August 2025, date last accessed).
48. Brigham E, Hopper N. No safety in numbers: traffic analysis of sealed-sender groups in Signal. 2025 22nd Annual International Conference on Privacy, Security, and Trust (PST), Fredericton, NB, Canada, 2025, pp. 1–10. https://10.1109/PST65910.2025.11268871
49. Pedersen AM, Udsen H, Jakobsen SS. Data retention in Europe—the Tele 2 case and beyond. *Int Data Priv Law* 2018;**8**:160–74. https://doi.org/10.1093/idpl/ipx026
50. Celeste E. The court of justice and the ban on bulk data retention: expansive potential and future scenarios. *Eur Const*

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

Law Rev 2019;**15**:134–57. https://doi.org/10.1017/S1574019619000038
51. Cameron I. Metadata retention and national security: Privacy International and La Quadrature du Net. *COLA* 2021;**58**:1433–72. https://doi.org/10.54648/COLA2021088
52. Bartusek J, Garg S, Jain A *et al. End-to-End Secure Messaging with Traceability Only for Illegal Content*. Washington: International Association for Cryptologic Research, 2022. https://eprint.iacr.org/2022/1643 (22 August 2025, date last accessed).
53. European Union Agency for Cybersecurity (ENISA). Security in 5G specifications—controls in 3GPP. 2021. https://www.enisa.europa.eu/publications/security-in-5g-specifications (22 August 2025, date last accessed).
54. Commission Recommendation (EU) 2019/534 of 26 March 2019 Cybersecurity of 5G networks [2019]OJ L88/42.
55. European Commission. 5G for Europe: an action plan. COM (2016) 588 final, SWD (2016) 306 final. Brussels 2016.
56. Royal United Services Institute for Defence and Security Studies. Balancing end-to-end encryption and public safety. London, 2021. https://static.rusi.org/325-OP-E2EE.pdf (22 August 2025, date last accessed).
57. Froomkin AM. It came from planet clipper: the battle over cryptographic key 'Escrow'. Chicago: University of Chicago Legal Forum, 1996, 15–76.
58. Blaze M, Feigenbaum J, Lacy J. Decentralized trust management. In: *Proceedings of the 1996 IEEE Symposium on Security and Privacy* . Piscataway, NJ: IEEE, 1996, 164–73. https://doi.org/10.1109/SECPRI.1996.502679
59. Walden I. Law enforcement access to data in clouds. In: C Millard (ed.), *Cloud Computing Law*. Oxford: Oxford University Press, 2013, 285–310. https://doi.org/10.1093/acprof:oso/9780199671670.003.0011
60. Cybercrime Convention Committee (T-CY). Assessing Article 19 Budapest Convention on the search and seizure of stored computer data. Assessment Report T-CY (2023)4. 2024. https://rm.coe.int/t-cy-2023-4-assessment-rep-v92-12-dec-2024-/1680b2e13c (22 August 2025, date last accessed).
61. Casey K. Closing the loophole: effects of Apple's new advanced data protection for iCloud. *J High Technol Law* 2023. https://sites.suffolk.edu/jhtl/2023/03/04/closing-the-loophole-effects-of-apples-new-advanced-data-protection-for-icloud/ (22 August 2025, date last accessed).
62. Apple. iCloud Data Security Overview. 2022. https://support.apple.com/en-us/102651 (22 August 2025, date last accessed).
63. Kaminsky S. Telegram security: a sober look at the current situation. Kaspersky, 2024. https://www.kaspersky.com.au/blog/telegram-privacy-security-backup-aug2024/34027/ (22 August 2025, date last accessed)
64. Internet Society. Preemptive monitoring in end-to-end encrypted services: technical feasibility evaluation. 2024. https://cli.re/2oQVn3 (22 August 2025, date last accessed).
65. Human Rights Council. The right to privacy in the digital age. *Report of the Office of the United Nations High Commissioner for Human Rights. UN Doc A/HRC/51/17.* 2022.
66. Ludvigsen KR, Nagaraja S, Daly A. YASM (Yet Another Surveillance Mechanism). arXiv:2205.14601. Preprint, arXiv. 2022. http://arxiv.org/abs/2205.14601 (5 October 2022, date last accessed).
67. Abelson H, Anderson R, Bellovin SM *et al.* Bugs in our pockets: the risks of client-side scanning. *J Cybersecur* 2024;**10**:tyad020. https://doi.org/10.1093/cybsec/tyad020
68. Hern A. Kaspersky: security firm tries to win back trust after Russian spying scandal. The Guardian, 2017. https://cli.re/4nQnKe (22 August 2025, date last accessed).
69. Russia. Федеральный закон от 6 июля 2016 г. N 374-ФЗ [Federal Law No. 374-FZ of 6 July 2016, Yarovaya Law].
70. Zhuravlev MS, Brazhnik TA. Russian data retention requirements: obligation to store the content of communications. *Comput Law Secur Rev* 2018;**34**:496–507. https://doi.org/10.1016/j.clsr.2017.11.011
71. *Digital Rights Ireland Ltd v Minister for Communications, Marine and Natural Resources and Others* (Joined Cases C-293/12 and C-594/12) EU:C:2014:238.
72. Sivetc L. Controlling free expression "by infrastructure" in the Russian Internet: the consequences of RuNet sovereignization. Vol. **26**. First Monday, 2021. https://doi.org/10.5210/fm.v26i5.11698
73. Lenaerts K. Limits on limitations: the essence of fundamental rights in the EU. *German Law J* 2019;**20**:779–93. https://doi.org/10.1017/glj.2019.62
74. Human Rights Council. Encryption and anonymity follow-up report. UN Doc A/HRC/38/35/Add.5. Geneva, 2018. https://docs.un.org/en/A/HRC/38/35/Add.5 *(22 August 2025, date last accessed).*
75. Moyakine E, Tabachnik A. Struggling to strike the right balance between interests at stake: the "Yarovaya", "Fake News" and "Disrespect" laws as examples of ill-conceived legislation in the age of modern technology.' *Comput Law Secur Rev* 2020;**40**;105512. https://doi.org/10.1016/j.clsr.2020.105512
76. Wijermars M. Selling internet control: the framing of the Russian ban of messaging app Telegram. *Inf Commun Soc* 2022;**25**:2190–206. https://doi.org/10.1080/1369118X.2021.1933562
77. *Podchasov v Russia* App no 33696/19 (ECtHR, 19 October 2023).
78. Shurson J. A European right to end-to-end encryption? *Comput Law Secur Rev* 2024;**55**:106063. https://doi.org/10.1016/j.clsr.2024.106063
79. M.N. (EncroChat) Case C-670/22 (Court of Justice, Grand Chamber, 30 April 2024) EU:C:2024:303.
80. Griffiths C, Jackson A. Intercepted communications as evidence: the admissibility of material obtained from the encrypted messaging service EncroChat: *r v A, B, D & C* [2021]EWCA Crim 128. *J Crim Law* 2022;**86**:271–6. https://doi.org/10.1177/00220183221113455
81. Oerlemans JJ, Toor DAGv. Legal aspects of the EncroChat operation: a human rights perspective. *Eur J Crime Crim Law Crim Just* 2022;**30**:309–28. https://doi.org/10.1163/15718174-bja10037
82. Stoykova R. Encrochat: the hacker with a warrant and fair trials? *Forensic Sci Int Digit Invest* 2023;**46**:301602. https://doi.org/10.1016/j.fsidi.2023.301602
83. United States. Stored Communications Act, 18 USC §§ 2701–2712.

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

84. Kerr OS. A user's guide to the Stored Communications Act, and a legislator's guide to amending it. *George Washing Law Rev* 2004;**72**:1208–49.
85. Kerr OS. The case for the third-party doctrine. *Mich L Rev* 2008;**107**:561–602.
86. Richards N. The third party doctrine and the future of the Cloud. *Washing Univ Law Rev* 2016;**94**:1441–92.
87. Kahney L. The FBI wanted a back door to the iPhone. Tim Cook said no. Wired, 16 April 2019. https://www.wired.com/story/the-time-tim-cook-stood-his-ground-against-fbi/ (22 August 2025, date last accessed).
88. The FBI's request and the content of the court order are available on the EPIC website. https://epic.org/documents/apple-v-fbi-2/ (22 August 2025, date last accessed).
89. Notice of Objections to 16 February 2016 Order Compelling Apple Inc. to Assist Agents in Search. https://cli.re/NY8pwm (22 August 2025, date last accessed).
90. Reuters. Israeli firm helping FBI to open encrypted iPhone: Report, 23 March 2016. https://www.reuters.com/article/us-apple-encryption-cellebrite-idUSKCN0WP17J/ (22 August 2025, date last accessed).
91. Hack M. The implications of Apple's battle with the FBI. *Netw Secur* 2016;**2016**:8–10. https://doi.org/10.1016/S1353-4858(16)30068-X
92. United States. Eliminating abusive and rampant neglect of Interactive Technologies Act of 2020 (EARN IT Act), S 3398, 116th Congress. 2020.
93. Glynn C. Section 230 as First Amendment Rule. *Harv Law Rev* 2018;**131**:2027–48.
94. Cosson C. Tool without a handle: reflections on 20 years from Reno v. ACLU. Center for Internet and Society, 2017. https://cyberlaw.stanford.edu/blog/2017/06/tool-without-handle-reflections-20-years-reno-v-aclu (2 July 2025, date last accessed).
95. Castro D, McQuinn A. The exceptions to Section 230: how have the courts interpreted Section 230?. Washington: Information Technology and Innovation Foundation (ITIF), 2021. https://itif.org/publications/2021/02/22/exceptions-section-230-how-have-courts-interpreted-section-230/ *(22 August 2025, date last accessed).*
96. Pfefferkorn R. The EARN IT Act: how to ban end-to-end encryption without actually banning it. Stanford: Centre for Internet and Society, Stanford Law School, 2020. https://cli.re/EvYZZz (22 August 2025, date last accessed).
97. Campbell N, Morris J, Higgins A *et al.* Internet impact brief: how the US EARN IT Act threatens security, confidentiality, and safety online. Internet Society, 2022. https://cli.re/AY8JZx (22 August 2025, date last accessed).
98. Milmo D. UK demands ability to access Apple users' encrypted data. The Guardian, 2025. https://cli.re/RM9D7o (26 August 2025, date last accessed).
99. Privacy International. Privacy International's response to the UK Government consultation on revised notices regimes in the Investigatory Powers Act 2016. London, 2016. https://privacyinternational.org/sites/default/files/2023-07/23.07.27_IPA_Notices_Consultation_PI.pdf (26 August 2025, date last accessed).
100. Kleinman Z. Apple pulls data protection tool after UK Government security row. BBC News, 2025. https://www.bbc.com/news/articles/cgj54eq4vejo (26 August 2025, date last accessed).
101. Apple. Apple can no longer offer advanced data protection in the United Kingdom to new users. https://support.apple.com/en-us/122234 (26 August 2025, date last accessed).
102. Trengove M, Kazim E, Almeida D *et al.* A critical review of the Online Safety Bill. *Patterns* 2022;**3**:100544. https://doi.org/10.1016/j.patter.2022.100544.
103. Bliss L. The crown prosecution guidelines and grossly offensive comments: an analysis. *J Media Law* 2017;**9**:173–88. https://doi.org/10.1080/17577632.2017.1369574
104. UK Government. End-to-end encryption and child safety, 20 September 2023. https://cli.re/K5Rz23 (26 August 2025, date last accessed).
105. Law S. Effective enforcement of the Online Safety Act and Digital Services Act: unpacking the compliance and enforcement regimes of the UK and EU's online safety legislation. *J Media Law* 2024;**16**:263–300. https://doi.org/10.1080/17577632.2025.2459441
106. Office of Communications. Technology notices to deal with terrorism content and/or CSEA content: consultation on policy proposals for minimum standards of accuracy for accredited technologies, and guidance to providers. 2024. https://www.ofcom.org.uk/siteassets/resources/documents/consultations/category-1-10-weeks/consultation-technology-notices/main-document/technology-notices-consultation.pdf?v=388881 (26 August 2025, date last accessed).
107. Voge C, Wilton R. End-to-end encryption under the UK's Draft Online Safety Bill. Internet Society, 2022. https://www.internetsociety.org/resources/doc/2022/iib-encryption-uk-online-safety-bill/ (26 August 2025, date last accessed).
108. Goodin D. Signal CEO: we "1,000% Won't Participate" in UK Law to weaken encryption. Ars Technica, 2023. https://arstech24 July 2025nica.com/information-technology/2023/02/signal-vows-to-defy-uk-legislation-that-puts-e2e-encryption-in-the-crosshairs/ (24 July 2025, date last accessed).
109. Deb HL 6 September 2023, vol 832, col 458 (Lord Parkinson of Whitley Bay).
110. Office of Communications. Protecting people from illegal harms online: illegal content judgements guidance. 2024. https://www.ofcom.org.uk/siteassets/resources/documents/online-safety/information-for-industry/illegal-harms/illegal-content-judgements-guidance-icjg.pdf?v=387556 (26 August 2025, date last accessed).
111. Wahl T. Law enforcement experts: action against end-to-end encryption needed. Eucrim, 2024. https://eucrim.eu/news/law-enforcement-experts-action-against-end-to-end-encryption-needed/ (26 August 2025, date last accessed).
112. European Parliamentary Research Service. Europe's PegasusGate: countering Spyware abuse. 2022. https://cli.re/vY4WA8 (12 March 2024, date last accessed).
113. Regulation (EU) 2021/1232 of the European Parliament and of the Council of 14 July 2021 laying down temporary derogations from certain provisions of Directive 2002/58/EC as regards the use of technologies by number-independent interpersonal communications service providers for the process-

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026

ing of personal and other data for the purpose of combating online child sexual abuse [2021]OJ L274/41.
114. Rojszczak M. Preventing the dissemination of child sexual abuse material (CSAM) with surveillance technologies: the case of EU Regulation 2021/1232. *Comput Law Secur Rev* 2025;**56**:106097. https://doi.org/10.1016/j.clsr.2024.106097
115. Wilman FG. Two emerging principles of EU internet law: a comparative analysis of the prohibitions of general data retention and general monitoring obligations. *Comput Law Secur Rev* 2022;**46**:105728. https://doi.org/10.1016/j.clsr.2022.105728
116. Jasmontaite L, Kamara I, Zanfir-Fortuna G *et al.* Data protection by design and by default. *Eur Data Protect Law Rev* 2018;**4**:168–89. https://doi.org/10.21552/edpl/2018/2/7
117. Albrecht JP. How the GDPR will change the world. *Eur Data Protect Law Rev* 2016;**2**:287–9. https://doi.org/10.21552/EDPL/2016/3/4
118. Ryngaert C, Taylor M. The GDPR as Global Data Protection Regulation? *AJIL Unbound* 2020;**114**:5–9. https://doi.org/10.1017/aju.2019.80
119. Fahey E. *The EU as a Global Digital Actor Institutionalising Global Data Protection, Trade, and CybersecurityModern Studies in European Law*. Vol. **111**. Oxford, New York: Hart Publishing, 2022. https://doi.org/10.5040/9781509957071
120. Bradford A. *The Brussels Effect: How the European Union Rules the World*. New York: Oxford University Press, 2020. https://doi.org/10.1093/oso/9780190088583.001.0001
121. Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications) [2002]OJ L201/37.
122. European Commission. Commission Work Programme 2025: moving forward together—a bolder, simpler, faster union. Annexes 1–5. COM(2025) 45 final.Brussels, 2025.
123. UK Government. End-to-end encryption and child safety: guidance. 2023. https://www.gov.uk/government/publications/end-to-end-encryption-and-child-safety/end-to-end-encryption-and-child-safety (18 July 2025, date last accessed).
124. Scheffler S, Kulshrestha A, Mayer J. Public verification for private hash matching. In: *Proceedings of the 2023 IEEE Symposium on Security and Privacy (SP)*. Piscataway: IEEE, 2023, 253–73. https://doi.org/10.1109/SP46215.2023.10179349
125. Bleakley P, Martellozzo E, Spence R *et al.* Moderating online child sexual abuse material (CSAM): does self-regulation work, or is greater state regulation needed? *Eur J Criminol* 2023:14773708231181361. https://doi.org/10.1177/14773708231181361
126. Zetzsche DA, Arner DW, Buckley RP. Decentralized finance. *J Finan Regul* 2020;**6**:172–203. https://doi.org/10.1093/jfr/fjaa010
127. Chainho P, Drusedow S, Pereira RL *et al.* Decentralized communications: trustworthy interoperability in peer-to-peer networks. In: *Proceedings of the 2017 European Conference on Networks and Communications (EuCNC)*. Piscataway: IEEE, 2017, 1–5. https://doi.org/10.1109/EuCNC.2017.7980649
128. Datta A, Buchegger S, Vu LH *et al.* Decentralized online social networks. In: B Furht (ed.), *Handbook of Social Network Technologies and Applications*. New York: Springer, 2010, 349–78. https://doi.org/10.1007/978-1-4419-7142-5_17
129. Kleppmann M, Frazee P, Gold J *et al.* Bluesky and the AT protocol: usable decentralized social media. In: *Proceedings of the ACM Conext-2024 Workshop on the Decentralization of the Internet (DIN '24)* . New York: ACM, 2024, 1–7. https://doi.org/10.1145/3694809.370074
130. Ferreira A. Decentralized finance (DeFi): the ultimate regulatory frontier? *Capital Markets Law Journal* 2024;**19**:242–59. https://doi.org/10.1093/cmlj/kmae007
131. OECD. Transparency Reporting on Terrorist and Violent Extremist Content Online. 4th edn. OECD Digital Economy Papers No 367. Paris, 2024. https://cli.re/BY9Mjr (22 August 2025, date last accessed).

Received: 3 October 2025. **Revised:** 12 February 2026. **Accepted:** 23 March 2026
© The Author(s) 2026. Published by Oxford University Press. This is an Open Access article distributed under the terms of the Creative Commons Attribution License (https://creativecommons.org/licenses/by/4.0/), which permits unrestricted reuse, distribution, and reproduction in any medium, provided the original work is properly cited.

Downloaded from academic.oup.com/cybersecurity/article/12/1/tyag010/8677339 by guest on 27 October 2026